AUTHORIZATION DEPENDS ON AUTHENTICATION

Authorization decisions are only as reliable as the identity upon which they rely. If authentication is weak or easily spoofed, access control policies may mistakenly grant permissions to the wrong party. In the Target breach we discussed in chapter 1, attackers used stolen credentials from an HVAC vendor to access the network—the system mistakenly recognized the attacker as a trusted third party. Authorization failed not because the policy was flawed, but because the identity was misrepresented.

This is why identity systems must be designed with both authentication and authorization in mind. The principle of "garbage in, garbage out" applies—faulty or ambiguous identity input leads to poor authorization decisions. We'll explore authentication in detail in chapter 3.

One of the primary ways that identity systems provide utility is by enabling access control and determining what actions the subject can take. The context of a relationship often defines the scope of access. For example, a system for managing an employer-employee relationship will provide utility by ensuring that employees have convenient access to the tools and information they need to do their jobs without compromising security or privacy. In a customer-service provider relationship, like the one I mentioned with Amazon, the identity system is more concerned with storing information about the customer for use in making purchases, but authorization still plays a role in enabling useful features like wish list sharing.

Policy-based authorization systems that move authorization out of the code and static lists expand the role of digital identity systems. By making policy the central focus of authorization, these systems support the increased use of dynamic authorization in both product and security.